

③ データマイニング

データマイニングは、蓄積した膨大なデータをコンピュータを使って解析し、役に立つ情報を発見する技術です。

④ スマートグリッド

スマートグリッドは、大規模な発電所や再生可能エネルギーを含めた分散型電源の供給側と電力の需要側を、情報通信技術を使って制御して、最適化する技術です。

⑤ ウェブアクセシビリティ

ウェブアクセシビリティは、年齢や身体的制約、利用環境などに拘らず、Webサイトにアクセスでき、サイト内のサービスを利用できるかどうかの度合いをいいます。

⑥ デジタルデバイド

デジタルデバイドは、コンピュータやインターネットを利用できる人とそうでない人の間に生じる情報格差をいいます。

(d) デジタル変革技術

① デジタルトランスフォーメーション (DX)

デジタルトランスフォーメーションは、デジタルの変革と訳され、デジタル技術の普及によって産業構造や社会基盤までが変革されるという意味です。

② デジタルディスラプション

デジタルディスラプションは、デジタル技術やそれを使った新たなビジネスモデルによって生じる、破壊的なイノベーションを意味します。

③ デジタルファブリケーション

デジタルファブリケーションとは、デジタルデータを使って創造物を製作する技術のことです。具体的には、3D スキャナや3D CADなどの機器を使って、自分のアイデアや、生物や物体のデータ等をデジタルデータ化した上で、デジタル工作機械を使って造形する手法をいいます。

④ デジタイゼーション

デジタイゼーションとは、デジタル技術を用いて製品やサービスの効率

化や付加価値を高める手法をいいます。

⑤ デジタルツイン

デジタルツインとは、現実空間の情報から収集したさまざまなデータを、まるで双子のようにコンピュータ上のサイバー空間内に再現する技術をいいます。

⑥ 人工知能 (AI)

人工知能に関しては、平成元年8月にAIネットワーク社会推進会議（総務省）によって示された別紙1「AI利活用ガイドライン～AI利活用のためのブラクティカルリファレンス～」という資料があります。その資料の序文では、「AIは、利活用の過程でデータの学習等により自らの出力やプログラムを継続的に変化させる可能性があることから、開発者が留意することが期待される事項のみならず、利用者がAIの利活用において留意することが期待される事項も想定される。」と示しています。また、AI利活用原則の基本理念として、次の内容を示しています。

【基本理念】

- ・人間がAIネットワークと共生することにより、その恵沢がすべての人によってあまねく享受され、人間の尊厳と個人の自律が尊重される人間中心の社会を実現すること
- ・AIの利活用において利用者の多様性を尊重し、多様な背景と価値観、考え方を持つ人々を包摂すること
- ・AIネットワーク化により個人、地域社会、各国、国際社会が抱える様々な課題の解決を図り、持続可能な社会を実現すること
- ・AIネットワーク化による便益を増進するとともに、民主主義社会の価値を最大限尊重しつつ、権利利益が侵害されるリスクを抑制するため、便益とリスクの適正なバランスを確保すること
- ・AIに関して有していると期待される能力や知識等に応じ、ステークホルダ間における適切な役割分担を実現すること

- ・AIの利活用の在り方について、非拘束的なソフトローたる指針やベストプラクティスを国際的に共有すること
- ・AIネットワーク化の進展等を踏まえ、国際的な議論を通じて、本ガイドラインを不断に見直し、必要に応じて柔軟に改定すること

また、次のAI利活用原則を示しています。

1) 適正利用の原則

AIサービスプロバイダ及びビジネス利用者は、AIによりなされた判断について、必要かつ可能な場合には、その判断を用いるか否か、あるいは、どのように用いるか等に関し、人間の判断を介在させることが期待される。(人間の判断の介在の一部を引用)

2) 適正学習の原則

AIによりなされる判断は、事後的に精度が損われたり、低下することが想定されるため、想定される権利侵害の規模、権利侵害の生じる頻度、技術水準、精度を維持するためのコスト等を踏まえ、あらかじめ精度に関する基準を定めておくことが期待される。(AIの学習等に用いるデータの質への留意の一部を引用)

3) 連携の原則

AIが連携することによって便益が増進することが期待されるが、AIサービスプロバイダ及びビジネス利用者は、自ら利用するAIがインターネット等を通じて他のAI等と接続・連携することにより制御不能となる等、AIがネットワーク化することによってリスクが惹起・増幅される可能性がある。(AIネットワーク化により惹起・増幅される課題への留意の一部を引用)

4) 安全の原則

人の生命・身体・財産に危害を及ぼし得る分野でAIを活用する場合には、AIサービスプロバイダ及びビジネス利用者は、想定される被害の性

質・態様等を踏まえ、開発者からの情報をもとに、必要に応じた対応策を講ずることにより、AIがアクチュエータ等を通じて人の生命・身体・財産に危害を及ぼすことのないよう配慮することが期待される。(人の生命・身体・財産への配慮の一部を引用)

5) セキュリティの原則

AIサービスプロバイダ、ビジネス利用者及びデータ提供者は、学習モデルの生成及びその管理において、セキュリティに脆弱性が存在するリスクに留意することが期待される。また、消費者的利用者に対し、そのようリスクが存在することを予め周知することが期待される。(AIの学習モデルに対するセキュリティ脆弱性の留意の一部を引用)

6) プライバシーの原則

7) 尊厳・自律の原則

AIサービスプロバイダ及びビジネス利用者は、消費者的利用者にはAIにより意思決定や感情が操作される可能性や、AIに過度に依存するリスクが存在することを踏まえ、必要な対策を講じることが期待される。(AIによる意思決定・感情の操作等への留意の一部を引用)

8) 公平性の原則

AIサービスプロバイダ及びビジネス利用者は、AIに用いられる学習アルゴリズムにより、AIの判断にバイアスが生じる可能性があることに留意することが期待される。特に、機械学習においては、一般的に、多数派がより尊重され、少数派が反映されにくい傾向にあり(バンドワゴン効果)、この課題を回避するための方法が検討されている。(学習アルゴリズムによるバイアスへの留意の一部を引用)

9) 透明性の原則

10) アカウタビリティの原則

⑦ 画像認識

画像認識とは、パターン認識の一種で、画像データから対象物の特徴をつ

かみ、対象物が何かを識別する技術です。最近では、ディープラーニング等のAI技術の進展によって、画像認識の認識精度は向上してきており、製造業の不良品検査や物流の積み下ろし作業だけでなく、防犯の顔認証や医療の画像診断などにも応用されています。なお、画像認識に使用できるクラウドサービスも提供されるようになってきています。画像認識技術のうち、顔認識技術は、プライバシー保護の面から、一般の人が懸念を持っているため、情報の漏えい対策や画像データの保存を行わないなどの対策が行われて使用されています。

⑧ ブロックチェーン

ブロックチェーンは、ネットワーク上にある多数のコンピュータを直接接続し、取引情報などを分散処理・記録する手法で、仮想通貨のビットコインの根幹をなす技術です。ブロックチェーンでは、データを保管するノードを多数配置し、P2P (Peer to Peer) ネットワークを使って取引履歴を分散管理しています。そのため、ネットワークの一部に不具合が生じてシステムを維持することができますので、高可用性を実現できます。また、ブロックチェーンでは、ドキュメントやデータの発行者の確認は電子署名で行われており、途中での改ざんを確認する技術であるハッシュ関数によるハッシュ値を用いていますので、改ざん耐性は高くなっています。ただし、ブロックチェーンでは、データをP2Pネットワーク全体で共有するので、秘匿性は低くなります。

ブロックチェーン技術を使った仕組みとして最近注目されているものとしてNFTがあります。NFTとは、Non-Fungible Token (非代替性トークン)の略で、偽造不可能な鑑定書・所有権証明書付きのデジタルデータと言い換えることができます。

⑨ スマートコントラクト

スマートコントラクトは、プログラムに基づいて自動的に実行される契約であり、ブロックチェーン上でも、当事者間の取引をプログラムとしてブロックチェーン上に記載し、契約の執行条件が満たされたら自動的に契約が執

行される仕組みを作ることができます。

⑩ ドローン

ドローンとは無人航空機のことです。航空法の第2条で、「『無人航空機』とは、航空の用に供することができる飛行機、回転翼航空機、滑空機、飛行船その他政令で定める機器であつて構造上人が乗ることができないもののうち、遠隔操作又は自動操縦により飛行させることができるものをいう。」と定義されています。なお、ドローンの飛行条件として、以下の内容が規定されています。

- 1) 日中(日出から日没まで)において飛行させる
- 2) 無人航空機とその周辺を目視により常時監視する
- 3) 人や物件(建物等)との間に30mの距離を保って飛行させる
- 4) 多数の者が集合する催しが行われている場所の上空で飛行させない
- 5) 火薬類、高圧ガス、引火性液体、凶器などの危険物を輸送しない
- 6) 機体から物件を投下しない

⑪ RPA

RPAとは、Robotic Process Automationの略で、これまで人のみに対応してきた作業やそれより高度な作業を、人に代わってロボットや人工知能が代替して実施するものです。

⑫ ITS

ITSとは、Intelligent Transport System (高度道路交通システム)の略で、最先端の情報通信技術等を用いて、人と道路と車両とを一体のシステムとして構築することにより、ナビゲーションシステムの高度化、有料道路等の自動料金収受システムの確立、安全運転の支援、交通管理の最適化、道路管理の効率化等を図るものであると国土交通省は説明しています。

⑬ 自動運転

自動運転については、国土交通省自動車局より、「自動運転車の安全ガイドライン」が出されており、そのなかで、図表3.6に示す自動運転化レベルが定義されています。

図表 3.6 自動運転化レベルの定義の概要

レベル	名称	定義概要	安全運転に係る 監視、対応主体
運転者が一部又は全ての動的運転タスクを実行			
0	運転自動化なし	運転者が全ての動的運転タスクを実行	運転者
1	運転支援	システムが縦方向又は横方向のいずれかの車両運動制御のサブタスクを限定領域において実行	運転者
2	部分運転自動化	システムが縦方向及び横方向両方の車両運動制御のサブタスクを限定領域において実行	運転者
自動運転システムが（作動時は）全ての運転タスクを実行			
3	条件付運転自動化	システムが全ての動的運転タスクを限定領域において実行 作動継続が困難な場合は、システムの介入要求等に適切に応答	システム（作動継続が困難な場合は運転者）
4	高度運転自動化	システムが全ての動的運転タスク及び作動継続が困難な場合への応答を限定領域において実行	システム
5	完全運転自動化	システムが全ての動的運転タスク及び作動継続が困難な場合への応答を無制限に（すなわち、限定領域ないではない）実行	システム

出典：自動運転車の安全ガイドライン（国土交通省自動車局）

(e) 通信技術

通信技術に関する用語について下記に示します。

① 5G

5G は、高速・大容量化に加えて、低遅延や多数同時接続という特徴を持っています。低遅延の実現によって、自動運転への活用やドローンなどの管制への活用が期待されていますし、多数同時接続によって IoT (Internet of Things) や M2M (Machine to Machine) への活用が期待されます。

② Wi-Fi

Wi-Fi は、一般的なデータ受信速度が 600 Mbps 程度と高速通信が可能で、狭い範囲で通信が可能です。

③ Bluetooth

Bluetooth は、近距離無線通信のインターフェイス規格で、通信速度は 1 Mbps 程度と低速で、伝送距離は 10 m 程度です。

④ LPWA (Low Power Wide Area)

LPWA の通信速度は、数 kbps から数百 kbps 程度と携帯電話システムと比較して低速で、低消費電力ですが、数 km から数十 km もの通信が可能な広域性を有しています。そのため、低コストの IoT ネットを構築できます。

5. 情報セキュリティ

情報セキュリティのリスクは年々高まってきており、それによって企業や組織が受けるダメージも大きくなってきています。

(1) 情報セキュリティ関連法規

情報セキュリティ関連法規のうち、サイバーセキュリティ基本法、特定電子メールの送信の適正化等に関する法律について説明します。

(a) サイバーセキュリティ基本法

サイバーセキュリティ基本法は、世界的規模で生じているサイバーセキュリティに対する脅威の深刻化に対し、情報の自由な流通を確保しつつ、サイバーセキュリティの確保を図るために、国や地方公共団体の責務等を明らかにしています。なお、サイバーセキュリティとは、「電磁的方式により記録、発信、伝送、受信される情報の漏えい、滅失、毀損の防止、情報の安全管理、情報通信ネットワークの安全性と信頼性の確保のために必要な措置が講じられ、その状態が適切に維持管理されていること」をいいます。それぞれの団体の責務は次のとおり定められています。

1) 国の責務（第4条）

基本理念にのっとり、サイバーセキュリティに関する総合的な施策を策定し、実施する責務

2) 地方公共団体の責務（第5条）

基本理念にのっとり、国との適切な役割分担を踏まえて、サイバーセキュリティに関する自主的な施策を策定し、実施する責務

3) 重要社会基盤事業者の責務（第6条）

基本理念にのっとり、そのサービスを安定的かつ適切に提供するため、サイバーセキュリティの重要性に関する関心と理解を深め、自主的かつ積極的にサイバーセキュリティの確保に努めるとともに、国や地方公共団体が実施するサイバーセキュリティに関する施策に協力するよう努める

4) サイバー関連事業者その他の事業者の責務（第7条）

基本理念にのっとり、その事業活動に関し、自主的かつ積極的にサイバーセキュリティの確保に努めるとともに、国や地方公共団体が実施するサイバーセキュリティに関する施策に協力するよう努める

5) 教育研究機関の責務（第8条）

基本理念にのっとり、自主的かつ積極的にサイバーセキュリティの確保、サイバーセキュリティに係る人材の育成やサイバーセキュリティに関する研究、その成果の普及に努めるとともに、国や地方公共団体が実施するサイバーセキュリティに関する施策に協力するよう努める

6) 国民の努力（第9条）

基本理念にのっとり、サイバーセキュリティの重要性に関する関心と理解を深め、サイバーセキュリティの確保に必要な注意を払うよう努める

(b) 特定電子メールの送信の適正化等に関する法律

特定電子メールの送信の適正化等に関する法律の目的は、「一時に多数の者に対してされる特定電子メールの送信等による電子メールの送受信上の支障を防止する必要性が生じていることにかんがみ、特定電子メールの送信の適正化のための措置等を定めることにより、電子メールの利用についての良好な環境

の整備を図り、もって高度情報通信社会の健全な発展に寄与すること」と第1条に示されています。なお、「特定電子メール」を、「電子メールの送信をする者（営利を目的とする団体及び営業を営む場合における個人に限る。）が自己又は他人の営業につき広告又は宣伝を行うための手段として送信をする電子メール」と定義しています。

第2章の「特定電子メールの送信の適正化のための措置等」では、次のような事項を定めています。

1) 特定電子メールの送信の制限（第3条）

送信者は、次に掲げる者以外に対し、特定電子メールの送信をしてはなりません。また、送信者は、特定電子メールの送信をしないように求める旨の通知を受けたときは、その通知に示された意思に反して、特定電子メールの送信をしてはなりません。

- ・あらかじめ、特定電子メールの送信をするように求める旨または送信することに同意する旨を送信者または送信委託者に対し通知した者
- ・総務省令や内閣府令で定めるところにより自己の電子メールアドレスを送信者または送信委託者に対し通知した者
- ・特定電子メールを手段とする広告または宣伝に係る営業を営む者と取引関係にある者
- ・総務省令や内閣府令で定めるところにより、自己の電子メールアドレスを公表している団体または個人（個人にあっては、営業を営む者に限る。）

メールでの情報配信を承諾する行為をオプトイン、不参加または脱退する行為をオプトアウトといいます。

2) 表示義務（第4条）

送信者は、特定電子メールの送信の際は、その受信者が使用する通信端末機器の映像面に、次に掲げる事項が正しく表示されるようにしなければなりません。

- ・送信者の氏名または名称

・特定電子メールの送信をしないように求める旨の通知を受けるための電子メールアドレス、または電気通信設備を識別するための文字、番号、記号

3) 送信者情報を偽った送信の禁止（第5条）

送信に用いた電子メールアドレスや電気通信設備を識別するための文字、番号、記号その他の符号を偽って、特定電子メールの送信をしてはなりません。

(2) 情報セキュリティポリシー

JIS Q27000（情報技術—セキュリティ技術—情報セキュリティマネジメントシステム—用語）では、「情報セキュリティ」を「情報の機密性、完全性及び可用性を維持すること」と定義していますが、それぞれの言葉の意味を下記に示します。

① 機密性

機密性は、許可された人だけがアクセスでき、許可されない人はアクセスや閲覧ができないようにすることです。

② 完全性

完全性は、保有している情報が正確であり、情報の改ざんなどがなく、完全な状態を保持することです。

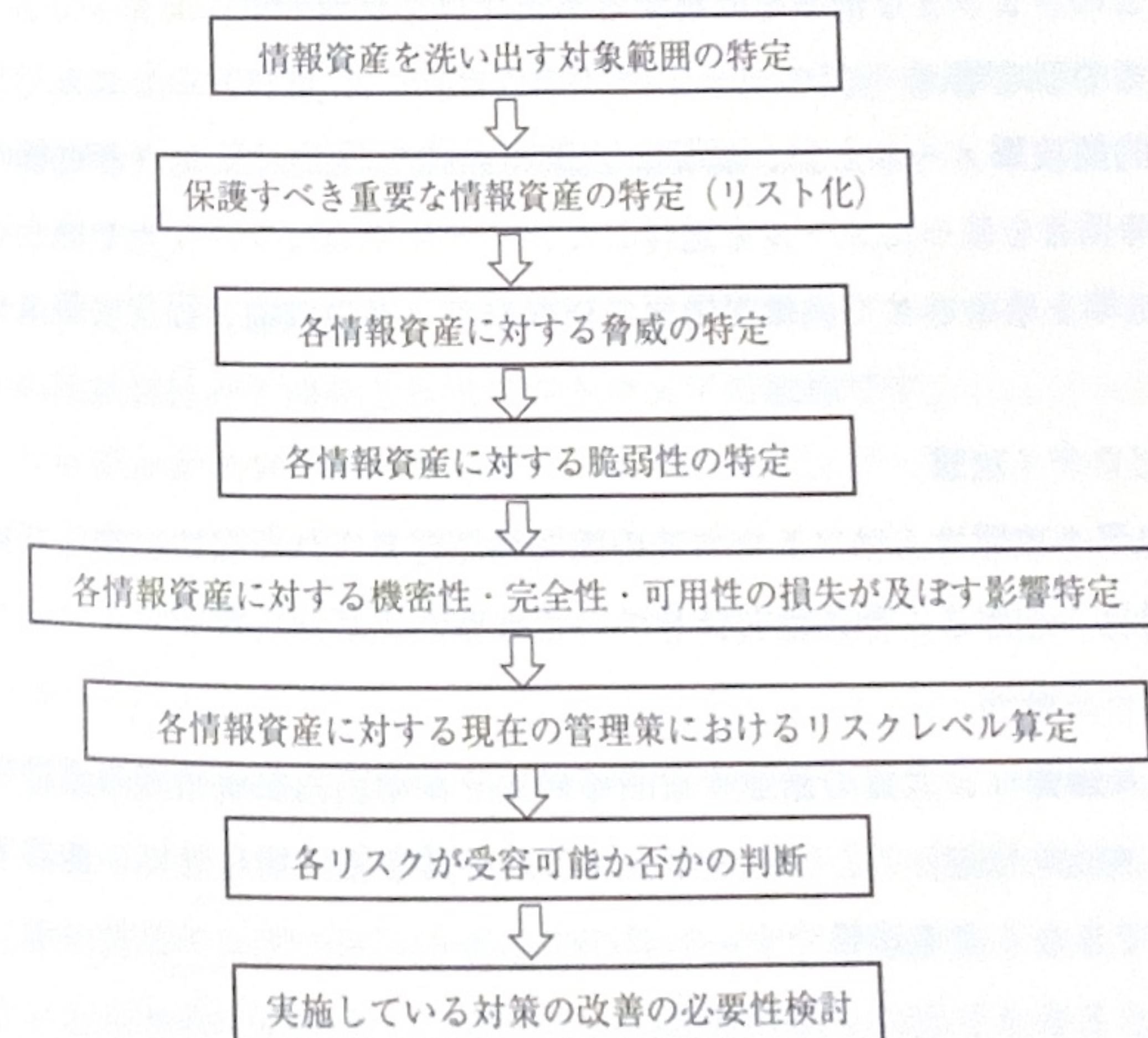
③ 可用性

可用性は、許可された人はいつでも情報にアクセスでき、情報を提供するシステムが常に動作していることです。

情報セキュリティを適切に維持できるようにするには、さまざまなリスクに対する情報セキュリティ対策が適切に行われていなければなりません。そのためには、企業や組織におけるセキュリティポリシーが必要となります。セキュリティ対策は、組織全体の問題ですので、特定の部署に限らず、組織全体として取り組む必要があります。そのため、セキュリティポリシーの策定には、組織の長が深く関与する必要があります。情報セキュリティポリシーは、基本方

針、対策基準、実施手順の3階層で構成されるのが一般的です。セキュリティポリシーは、情報セキュリティに関する活動を行うための基準となるもので、これに従って具体的な行動基準やマニュアル、ハード対策が検討されます。セキュリティ対策は、企業や組織の特性に合わせて作成される必要がありますので、自ら実現可能なものを作成することが望ましいとされています。また、どこまでセキュリティ対策を行うかについて、組織の規模やかけられる費用の面からの検討も必要です。

情報資産のリスク分析・評価は、図表 3.7 に示すステップで行われます。



図表 3.7 情報資産のリスク分析・評価手順

(3) 情報セキュリティの脅威

情報リスクにはさまざまなものがありますが、その中からいくつかを示します。

① サービス妨害攻撃

サービス妨害攻撃は **DoS 攻撃**ともいわれ、サーバーに大量のデータを送って過大な負荷をかけ、サーバーの性能を極端に低下させたり、サーバーを機能停止に追い込んだりする不正行為です。分散した多数のコンピュータから特定のコンピュータに一齐にパケットを送って機能を停止させる攻撃は**分散 DoS 攻撃**と呼ばれます。

② スパイウェア

スパイウェアは、ユーザーが気づかないうちにパソコンに侵入し、個人情報などのさまざまな情報を収集する不正プログラムです。

③ 標的型攻撃メール

標的型攻撃メールとは、特定の企業や組織を攻撃対象とする攻撃のことで、関係者を装ったメールを送付して、メールや添付ファイルを開かせ、ウイルス等を感染させて、機密情報の窃取やデータの破壊を行う攻撃メールです。

④ ゼロデイ攻撃

ゼロデイ攻撃は、ソフトウェアの脆弱性が発見された際に、修正プログラムの提供より前に、その脆弱性について行うサイバー攻撃です。

⑤ メール爆弾

メール爆弾は、大量の無意味な内容のメールや巨大なサイズの添付ファイル付きメールを送って、メールボックスの容量を使い切らせて、他のメールを受信できなくする攻撃です。

⑥ ボットネット

ボットとは、ロボットに由来する言葉で、標的になったコンピュータに送り込まれて密かに動作するものです。異なる複数のコンピュータに送り込んだボットが連携して動作するものをボットネットといいます。ボットネットは、自分のパソコンが知らないうちに操作されて加害者になる危険性も持っています。

⑦ フィッシング詐欺

フィッシング詐欺は、銀行やクレジット会社などを装った電子メールを送り、住所や氏名、口座番号などの情報を搾取する手法です。電子メールのリンクから偽サイトに誘導し、情報を入力させる手口が広く使われています。

⑧ ランサムウェア

ランサムウェアは、身代金ウイルスとも呼ばれ、感染すると端末がロックされたり、ファイルが勝手に暗号化されるため使用できなくなり、解除するために金銭を要求してくる不正プログラムです。

⑨ ビジネスメール詐欺

ビジネスメール詐欺は、実際の取引先や自社の経営者層等になりすまして、偽の電子メールを送って入金を促す詐欺のことです。

⑩ マルウェア

マルウェアは、ウイルス、ワーム、トロイの木馬、スパイウェアなど、何らかの悪意を持って開発されたソフトウェアの総称です。

⑪ ソーシャルエンジニアリング

ソーシャルエンジニアリングは、ネットワークに侵入するために必要なパスワード等を人間の弱みや心理的なスキについて搾取する手法のことです。

⑫ ネット炎上

令和元年度情報通信白書第1部第1章第4節第3項では、ネット炎上の発生件数はモバイルとSNSが普及し始めた2011年を境に急激に増加しており、炎上参加者はインターネット利用者の数パーセント程度以下のごく少数に過ぎないと示されています。また、炎上の確認経路を確認したところ、約半数以上の回答がテレビのバラエティ番組からであったと報告しています。政府としては、厚生労働省に「まもろうよ ところ」、総務省に「違法・有害情報相談センター」、法務省に「人権相談」の窓口を設けています。また、プロバイダ責任制限法第4条に「発信者情報の開示請求等」が規定されており、インターネット上の誹謗中傷を受けた者の被害回復のために、匿名の発信者を特定するための発信者の情報を開示する制度を設けています。

(4) 情報セキュリティ対策

最近では、ネットワークへの不正アクセスが問題となっていますので、そういった不正アクセスを防ぐ対策が必要となっています。ここでは、セキュリティ対策の用語について説明します。

① 共通鍵暗号方式

共通鍵暗号方式は、暗号化と復号化の両方に同じ鍵を用いる方法です。鍵を送信先に安全に渡す必要があります。鍵を秘密にするために、「秘密鍵暗号方式」ともいいます。共通鍵暗号方式は、ブロック暗号とストリーム暗号の2方式に分類できます。ブロック暗号は、一定のブロック単位で暗号化していく方式で、ストリーム暗号は、データを1ビット単位あるいは1バイト単位で逐次暗号化していく方式です。

② 公開鍵暗号方式

公開鍵暗号方式は、暗号化と復号化に異なる鍵を用いる方式で、暗号化に受信者が生成した公開鍵を使い、復号化に秘密鍵を使います。RSAはその代表的な方法です。RSAは、大きな数の素因数分解に要する時間が長くなることをベースに作られた暗号方式で、開発したメンバーの Ronald Rivest、Adi Shamir、Len Adleman の頭文字を取って命名されています。

③ 生体認証

生体認証は、人の生体的特徴・特性を用いて行う本人認証方式をいいます。この方法では、パスワードなどのように「忘れる」、カードなどの「紛失」、「盗難」、「置き忘れ」の問題を回避できますが、プライバシーの面でユーザーに抵抗感を持たれる場合があります。具体的には、指紋や掌形、網膜、瞳、顔などの認証方法が用いられており、銀行のATMや空港の出入国管理システムなどで実用化されています。生体認証では、入力特徴データと登録特徴データとの類似度の計算結果は、あらかじめ設定された閾値と比較され、本人との一致・不一致が判断されます。閾値のバランスを調整することで、運用者がシステム全体の目的に合わせて安全性と利便性のバランスを調整することができます。ただし、生体認証では、誤って他人を受け入れる可

能性と、誤って本人を拒否する可能性をゼロにすることはできません。

④ WEP (Wired Equivalent Privacy)

WEPは、IEEE802.11 無線 LAN 用のデータ暗号化機能で、共通暗号方式を使っており、暗号化は MAC 層で行います。暗号化の実装に問題があるため、解読に対する堪能性が低いという問題があります。そのため、「WPA」(Wi-Fi Protected Access) への代替が進められています。

⑤ アクセス制御

アクセス制御は、基本的なセキュリティ機能の1つで、アクセス権を設定して、誰が何に対してどういった権限を持っているかを識別し、操作の許可や拒否をする制御です。

⑥ SSL (Secure Sockets Layer)/TLS (Transport Layer Security)

SSLは、WWW サーバー間でやり取りをするデータのセキュリティを確保するための暗号化と認証機能を持っています。「TLS」は、SSL をバージョンアップさせたものから作られたプロトコルですが、SSL の名称が普及していたため、最近では SSL/TLS と表記されています。SSL/TLS では、信頼された認証局が、サイト運営会社が実在していることと暗号化通信の SSL サーバーの証明書を発行しています。SSL 暗号化通信が確立しているかどうかは、URL が “https:” となっていることで確認できます。

⑦ SSH (Secure SHell)

SSHは、セキュリティが低いネットワーク上において、遠隔で他のコンピュータを利用する場合に、セキュリティが高い遠隔ログインやデータ転送を実現させるプロトコルです。認証と暗号化の機能を持っており、認証には RSA 暗号や CHAP を使った認証を用い、暗号化には DES や IDEA のような共通鍵暗号を用います。

⑧ 電子証明書

電子証明書は、ネットワーク上での身分証明を行う手法で、公開鍵と秘密鍵、属性情報からなり、通常は認証局で発行されたものが用いられます。認証局とは、電子証明書の発行や有効性に関する情報提供を行う機関になります。

す。電子証明書を活用することで、なりすまし、改ざん、事後否認、盗聴のリスクを防ぐことができます。電子証明書は、電子入札や商業・法人登記、特許のインターネット出願などに利用されています。電子証明書の発行を受けたものは、電子証明書の有効期限前に失効させることができます。

⑨ 電子署名とデジタル署名

電子署名は、電子商取引で、データが正しい送信者から送られてきたか、送信内容が途中で改ざんされていないかなどを証明する手法です。

一方、**デジタル署名**は、ハッシュ関数と公開鍵暗号方式を組み合わせ、文章の作成者を証明し、データの完全性を確保する電子的な証明です。デジタル署名の手順は、送信者は、署名したいメッセージからハッシュ関数を使ってダイジェストを生成し、ダイジェストを送信者の秘密鍵で暗号化し、メッセージとともに送信します。受信者は、受信したメッセージからハッシュ関数を使ってダイジェストを生成し、署名を送信者の公開鍵で復号したダイジェストと比較して一致することを確認します。デジタル署名では、メッセージが改ざんされていないこととダイジェストを生成した人が確かに署名者であることを確認できますが、メッセージはそのまま送信されるため機密性は確保できません。

⑩ ファイアウォール

ファイアウォールは、LANとインターネットを接続する場合に、インターネット側（外部）からの攻撃や不正侵入が行われないようにする装置の総称です。

⑪ アクセスログ分析

アクセスログ分析は、サイトにいつアクセスし、どこのサイトから誘導されたのか、どれだけの訪問数があったのかの記録を分析することです。

⑫ 多要素認証

多要素認証は、セキュリティ向上のために、認証の3要素である、知識情報（パスワードなど）、所持情報（ICカードなど）、生体情報（指紋など）の2つ以上を組み合わせ、認証する方法をいいます。

⑬ Web会議サービスを使用する際のセキュリティ上の注意事項

Web会議サービスのクライアントソフトの脆弱性を狙った攻撃が増えているため、常に最新の状態にアップデートする必要があります。また、セキュリティを確保するためには、会議案内メールが意図しない参加者に届かないようにするとともに、会議参加者の確認・認証を適切に行う必要があります。さらに、Web会議では、参加者端末ののぞき見や機密情報の映り込みなどのリスクがあるため、参加者端末の場所、映像の背景に配慮しなければなりません。Web会議では音声や映像など多くの個人情報を扱う場合があるため、個人情報の漏えいを防ぐために、改正個人情報保護法等の法律、規制に準拠して行う必要があります。通信路が安全でない場合、エンドツーエンド暗号化方式を用いると、サーバーでの復号を必要とする機能が使えなくなる可能性があるため、注意する必要があります。

(5) 情報セキュリティ認証制度

情報システムやネットワークは社会において欠かせないものとなっている一方で、標的型攻撃などによる被害も増えてきています。そういった現状から、情報セキュリティマネジメントシステム (ISMS: Information Security Management System) や認証制度が注目されています。

① JIS Q 27001

JIS Q 27001の表題は、「情報セキュリティ、サイバーセキュリティ及びプライバシー保護—情報セキュリティマネジメントシステム—要求事項」で、情報セキュリティマネジメントシステム適合性評価制度が設けられています。

② ISO/IEC 15408

ISO/IEC 15408は、JIS X5070として制定されており、その表題は「セキュリティ技術—情報技術セキュリティの評価基準」です。そこでの認証制度は、ITセキュリティ評価及び認証制度です。

③ JIS Q 15001

JIS Q 15001の表題は、「個人情報保護マネジメントシステム—要求事項」

で、プライバシーマーク制度が設けられています。

(6) 情報セキュリティ問題の具体例

過去には、情報セキュリティに関して示された5つの選択肢文から、適切なものまたは不適切なものを選択する問題が出題されています。出題された問題から、適切な選択肢と不適切な選択肢を分けて示します。なお、適切なものと不適切なものを読み間違えないために、選択肢文の最初に、適切なものには○を、不適切なものには●を付けてあります。

(a) 適切な選択肢

- 商品を発注したという事実を発注者が後から否認することを防ぐため、発注情報を含む電子データに発注者のデジタル署名を施すよう受注者が依頼した。
- 委託先から最近のやりとりの内容と全く異なる不自然なメールが届いたため、標的型攻撃メールなどを疑い、添付ファイルは開かず、情報管理者にすぐに報告・相談した。
- 不正アクセスにより企業の顧客情報などの重要情報が漏洩するリスクを低減させるため、サーバーに保存してある重要情報が含まれるデータを暗号化した。
- 電子メールの差出人の名前を詐称するなりすましによる詐欺の被害を防ぐため、電子メールの受信者が、電子メールに施されたデジタル署名により差出人を特定した。
- 電子メールによる発注情報が途中で書き換えられて受注者に届く改ざんを防ぐため、発注情報を含む電子データに発注者のデジタル署名を施した。
- システム管理者を名乗る人から、システムに障害が発生したため利用者の再登録が必要との電話があり、利用者IDとパスワードを聞かれたが答えなかった。
- 情報漏えいを発見したので、直ちに上司や管理者に連絡した。
- 同一部門内であっても1台のスマートフォンを複数の人で共同利用しない。

い。

- 標的型攻撃メールの添付ファイルに仕掛けられたウイルスが既知であれば、ウイルス対策ソフトのウイルス定義ファイルを最新にしておくことで検知可能である。
- 従業員に標的型攻撃メールを疑似体験させることは、標的型攻撃メールに対する意識向上に有効である。
- 机の上をいつも整理しておくことは、重要な情報が放置された状態にならないように注意をすることになるので情報漏洩対策の1つである。
- 組織の情報漏洩対応では憶測や類推による判断や発言は混乱を招くので、情報を1か所に集め外部に対する情報提供や報告の窓口を1本化した。
- メールアドレスを間違えて社内情報を誤送信してしまったので、誤送信先にお詫びと送付情報の削除をお願いした。
- 匿名掲示板に自社のいわれなき悪評が書き込まれたので、掲示板の管理者に悪評の削除を申し入れた。
- 個人情報漏洩したので、本人にその事実を知らせてお詫びするとともに、詐欺や迷惑行為などの被害にあわないよう注意喚起をした。

(b) 不適切な選択肢

- オンラインショッピングサイトに送信するクレジットカード番号が第三者に盗まれないようにするため、ショッピング利用者が送信データにデジタル署名を施した。
- 重要情報を取引先にメールで送付する際に、インターネット上でのデータの機密性を確保するため、送信データに電子署名を施した。
- 職場のパソコンがランサムウェアに感染するのを予防するため、常にパソコンに接続している外付けハードディスクにパソコン内のデータをバックアップした。
- 振込先の変更を求めるメールが取引先から届いたため、ビジネスメール詐欺を疑い、メールへの返信ではなく、メールに書かれている番号に電話して確認した。

安全管理

安全は何よりも優先されなければならない事項といえます。そのため、技術者は安全に関する法律の規定を守って業務を遂行する場面が多くあります。それだけではなく、リスクや危機に対する対応や未然防止対策の検討などを行う必要もあります。この章では、安全管理と安全法規、安全に関するリスクマネジメント、労働安全衛生管理、事故・災害の未然防止活動・技術、危機管理、システム安全工学手法に分けて説明を行います。

1. 安全管理と安全法規

安全に関しては、事故や災害が起きるたびにさまざまな形で対策や管理手法などが作られてきています。安全マネジメントシステムとしては、ISO 45001（労働安全衛生マネジメントシステム）や ISO 31000（リスクマネジメント）が国際規格となっています。

（1）安全文化

安全を維持していくためには、安全文化という考え方も重要になっています。安全文化という考え方は、チェルノブイリ原発事故の原因調査をきっかけとして国際原子力機関が提唱したものであるとされています。安全文化を組織内に広げていくためには、次の4つの文化を育成していく必要があると米国の

- 公衆無線 LAN を用いてテレワークをする際に、通信傍受を防ぐため、WPA2 より暗号化強度が強い「WEP で保護」と表示されているアクセスポイントを利用した。
- 発信者名が知人であるメールアドレス変更通知に添付されていたファイルを、ウイルスチェックを行うことなく開いた。
- 職場の駐車場で拾った USB メモリの所有者を確認するために、職場のネットワークに接続されたパソコンに挿入した。
- 重要な業務データは、本体のメモリではなく、SD カード等のフラッシュメモリに保管する。
- セキュリティソフトを導入し、パターンファイルを最新に保つことで、アプリをインストールする際のアクセス許可の確認を不要にできる。
- 通信費を削減するため、提供元が不明であっても、無料で使える無線 LAN スポットを利用する。
- アプリが素早く使えることがスマートフォンの利点であることから、デバイスのロックのためのパスワード等はなしにするか、簡単に入力できるものにする。
- 標的型攻撃メールとは特定のプログラムを狙ったサイバー攻撃のメールである。
- 標的型攻撃メールにはファイルが必ず添付されている。
- 送信者のメールアドレスが自分と同じ組織のドメイン名であれば、イントラネット内の送受信であるので安全なメールである。
- 以前、安全にメールの送受信を行った実績のあるメールアドレスからのメールは安全なメールである。